AutoClip Information Security and Privacy Policy

Policy for the protection of customer, TikTok, TikTok Shop, and operational information

Document owner	AutoClip operator
Version	1.0
Approved on	To be completed upon formal approval
Effective date	Effective when approved and adopted by the AutoClip operator

Purpose. This policy describes the security and privacy controls AutoClip uses and the operating requirements it adopts for its SaaS service. It is intended for customers, personnel, service providers, and platform partners, including TikTok Shop. It must be formally approved and operated before it is represented as an effective company policy.

1. Scope and principles

This policy applies to AutoClip production systems, source code, cloud services, users with administrative or operational access, and information processed through the service. AutoClip applies least privilege, tenant separation, secure handling of secrets, and privacy-aware processing as core principles.

2. Information handled by the service

AutoClip may process account and workspace data, user identifiers and contact details, uploaded media and publication metadata, TikTok and TikTok Shop connection data, product and order cache data, and operational, audit, and diagnostic records. AutoClip processes this information only to provide, secure, support, and improve the service, meet legal obligations, and respond to incidents.

3. Identity access and tenant isolation

AutoClip uses authenticated user sessions and workspace-based roles: Owner, Admin, Editor, and Viewer. Database row-level security and authorization helpers restrict access by workspace and role. Application records are associated with a workspace, and database constraints link channels, media, publications, products, and related records to that workspace. Administrative actions are limited to designated platform owners and server-side administrative functions.

- Users receive only the access needed for their assigned workspace role.
- Workspace membership is checked before users access or modify workspace data.
- Service credentials and privileged database keys are kept out of the browser application.

4. OAuth tokens secrets and credentials

AutoClip processes TikTok and TikTok Shop authorization tokens in server-side functions. Tokens are encrypted before persistent storage using AES-256-GCM with a randomly generated 96-bit initialization vector. The encrypted value is bound to its channel or connection identifier as additional authenticated

data, so it cannot be successfully reused in another connection context. The encryption key is configured as a server secret and is not included in the frontend application. Browser clients cannot select the database records that contain TikTok Shop tokens; they receive only a restricted connection summary.

- OAuth authorization state values are single-use and time-limited.
- TikTok Shop token refresh and API signing occur in server-side functions.
- Secrets are provided through deployment configuration; they must not be committed to source control, exposed in client code, or written to ordinary support records.

5. Encryption and secure transmission

AutoClip is designed to use HTTPS endpoints for web access, OAuth redirects, TikTok and TikTok Shop API requests, and media delivery. Stored OAuth credentials are encrypted as described in Section 4. Media delivery uses short-lived signed tokens for the documented media proxy flow. AutoClip does not rely on encryption as a substitute for authorization; access decisions are also enforced through authenticated server functions, role checks, and database row-level security.

6. Data retention deletion and data subject requests

AutoClip retains service data while it is needed to operate the applicable workspace or meet a lawful purpose. A verified account-deletion request is processed through a controlled administrative path. When a workspace is deleted, related database records are removed through configured relationships, and the administrative deletion flow includes removal of workspace media from storage. Data may be retained only to the minimum extent necessary for security, fraud prevention, dispute resolution, legal obligations, or technical backup cycles. Requests may be submitted through the published AutoClip data-deletion channel.

7. Logging monitoring and auditability

AutoClip maintains application audit-log structures and records publication, connection, and operational events. Access to audit records is restricted to authorized workspace administrators or server-side operations, as applicable. Logs and diagnostic records must be handled as confidential operational data. Tokens, encryption keys, passwords, and other secrets must not be deliberately recorded in logs. Suspected anomalous activity, authorization failures, service errors, and security alerts are reviewed and escalated under Section 9.

8. Secure development vulnerability and supplier management

AutoClip maintains source-controlled application code, database migrations, and automated tests for key authorization and token-cryptography behaviors. Security-relevant changes must be reviewed before release, and identified vulnerabilities or dependency updates must be prioritized according to risk. Cloud and platform suppliers are selected and configured with regard to their ability to support AutoClip's security and privacy obligations. This policy does not assert a certification or control operated by a supplier beyond the supplier's own published commitments.

9. Security incident response and notification

AutoClip adopts the following incident process. This section is the documented procedure for identifying, containing, investigating, assessing, communicating, and recording security incidents. The AutoClip operator must assign a responsible incident lead and maintain the security contact channel before treating this procedure as operational.

Stage	Required action
Identify and triage	Any suspected unauthorized access, disclosure, loss, alteration, malware event, service compromise, or material availability event is recorded promptly. The incident lead assigns an initial severity and preserves available evidence.
Contain and protect	The team restricts access, revokes or rotates affected credentials or tokens where appropriate, isolates affected components, and takes proportionate steps to prevent further impact.
Investigate and assess	The team determines affected systems, data categories, tenants, individuals, duration, likely cause, and the risk of harm. The assessment is updated as facts become available.
Notify	Where required by applicable law, contract, or platform terms, AutoClip notifies affected customers, individuals, regulators, and relevant partners, including TikTok Shop when its data or integration may be affected, without undue delay and within applicable deadlines. Notices describe known facts, affected data, mitigation steps, and a contact point, subject to preserving evidence and security.
Recover and learn	The team restores services safely, verifies remediation, records decisions and communications, and tracks corrective actions to completion. A post-incident review is completed for material incidents.

10. Privacy and LGPD

AutoClip handles personal data in accordance with the purposes described in its published Privacy Policy and applicable privacy law, including Brazil's Lei Geral de Proteção de Dados Pessoais where applicable. AutoClip limits access to authorized roles, responds to verified data subject requests, applies safeguards proportionate to the nature of the data, and considers privacy impacts when changing processing activities.

11. Roles review and exceptions

The AutoClip operator is responsible for approving this policy, assigning the incident lead, maintaining the published privacy and deletion contact channels, and reviewing this policy at least annually and after a material security incident or major change to processing. Exceptions require documented approval and compensating safeguards appropriate to the risk.

12. Security contact

For security and privacy matters, including suspected incidents and data requests, contact: diogos.nascimento@outlook.com. The operator must monitor this channel and maintain a current escalation path after formal adoption of this policy.

Approval record

Legal entity or responsible operator	
Authorized approver name title date and signature	